# CP05 - Pipeline DevSecOps Completo

FIAP | Engenharia de Software | DevSecOps and Cloud Computing

Aluno: _____ RM: _____ Repositório: https://github.com/____/____

## 1. Visão geral

O repositório contém um site estático (nginx via Dockerfile) e o workflow **security.yml**, executado em todo push e pull request. O pipeline tem três jobs independentes: **Gitleaks** (segredos), **Semgrep** (SAST) e **Trivy** (CVE em imagem). Qualquer achado faz o job falhar e o status vermelho bloqueia o merge.

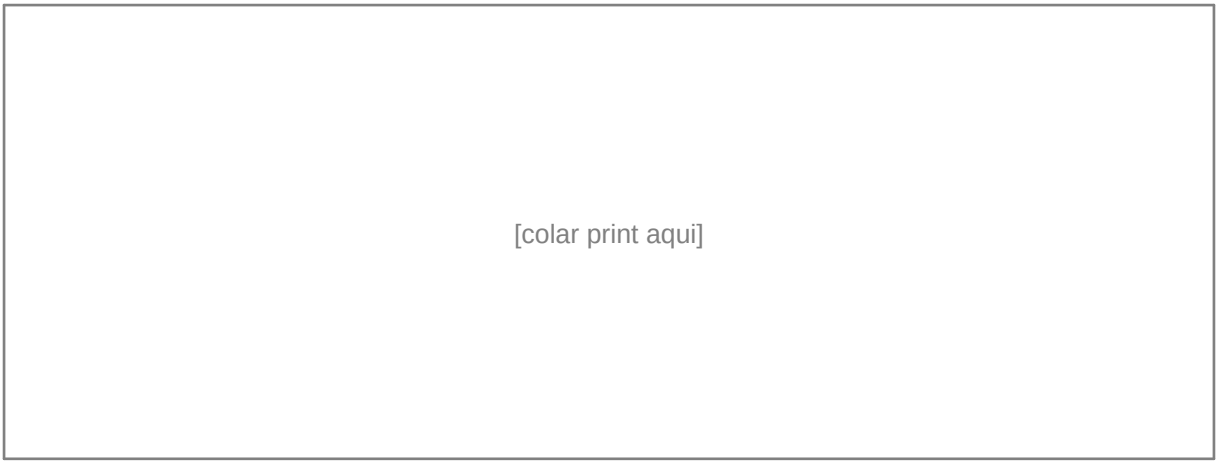
Print: Actions da branch main com os 3 jobs verdes

[colar print aqui]

## 2. Barreira 1 - Gitleaks (segredos)

O Gitleaks varre o conteúdo e todo o histórico de commits (fetch-depth: 0) procurando padrões de credenciais, como chaves de acesso AWS, tokens e chaves privadas. Neste teste, um commit com uma chave AWS falsa (formato de exemplo) foi enviado a um branch separado e o job falhou, apontando o arquivo, a linha e a regra violada. Isso importa porque um segredo commitado permanece no histórico do Git mesmo depois de apagado, então a barreira precisa agir antes do merge.

Print: job gitleaks FALHANDO



## 3. Barreira 2 - Semgrep (código vulnerável)

O Semgrep faz análise estática (SAST) comparando o código com regras. No teste, um arquivo usando **eval()** sobre entrada do usuário foi enviado a outro branch. O Semgrep apontou a linha como risco de injeção de código, e a flag --error fez o job falhar. A barreira evita que falhas conhecidas, como injeção, cheguem à produção.

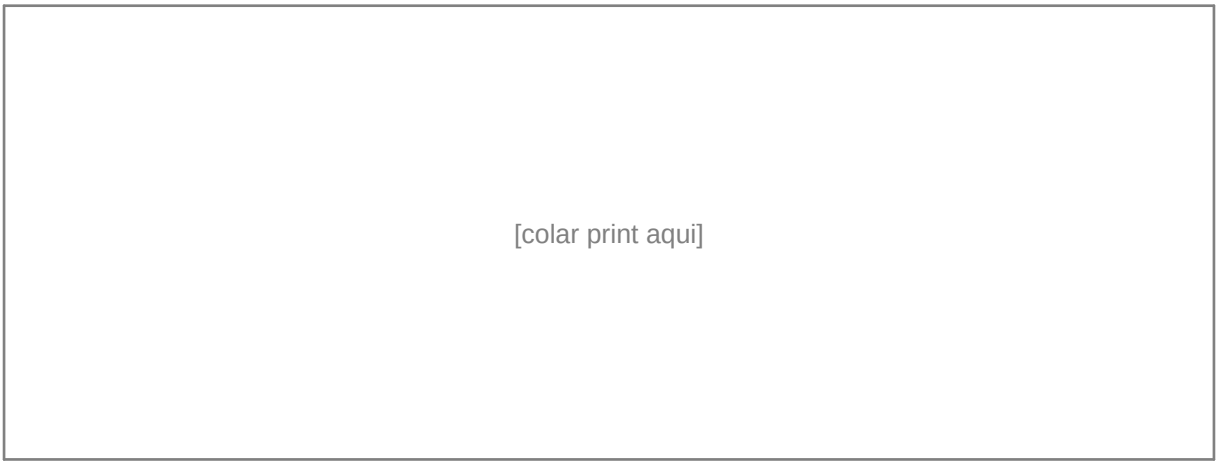
Print: job semgrep FALHANDO apontando eval

[colar print aqui]

## 4. Barreira 3 - Trivy (imagem com CVE crítico)

O Trivy escaneia a imagem Docker construída no pipeline em busca de vulnerabilidades conhecidas (CVEs). Configurado com severity CRITICAL e exit-code 1, ele reprova a imagem se houver CVE crítico com correção disponível. Isso protege contra dependências e imagens base desatualizadas.

Print: job trivy (verde na main, ou vermelho com base antiga)




## 5. Conclusão

As três barreiras cobrem camadas diferentes: o que o desenvolvedor commita (Gitleaks), o código que escreve (Semgrep) e o que empacota (Trivy). Os testes de sabotagem mostram que o pipeline realmente reprova, e não apenas existe no papel.